
Security Login Analytics Investigation

Technical Design Review

Detecting suspicious authentication behavior using
behavioral analytics

Prepared by Stasy | 10 158 login events | 2024-01-01 to 2024-03-29



The review moves from business risk to operating model

- Business problem
- Assignment understanding
- Analytical strategy
- Decision log
- Data understanding
- Data quality
- Exploratory analysis
- Baseline and features
- Anomaly investigation
- Threat kill chain
- Statistical confidence
- Heuristics versus ML
- Explainability and cost
- SOC workflow
- Dashboard design
- Product perspective
- Product KPI case
- Production architecture
- Limitations
- Recommendations

The throughline is not 'find weird rows'; it is reduce security risk with evidence that a SOC can act on.

Login monitoring protects revenue, trust, and compliance

Primary objective

Reduce risk

Without flooding analysts

False-positive cost

Alert fatigue

SOC capacity is finite

False-negative cost

Account takeover

Fraud, privacy, trust loss

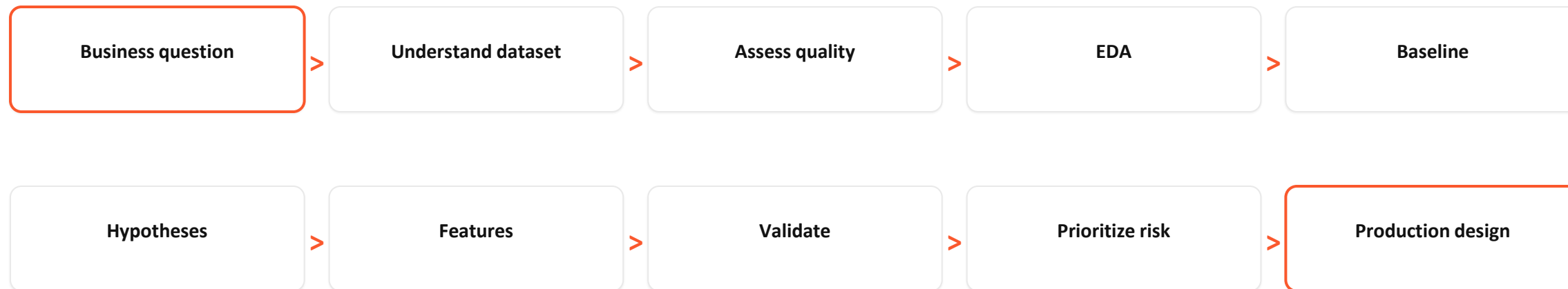
Threat	What login logs reveal	Business risk
Credential stuffing	Repeated failures, IP rotation	Compromised accounts
Password spraying	One IP across many users	Broad exposure
Automated bots	Machine-precise timing	Fraud and abuse
Insider or misuse	Off-hours or atypical access	Data loss and compliance

The assignment tests judgment, not just pandas syntax



A senior answer explains why the method is appropriate, where it can be wrong, and how it would become a production control.

The analytical sequence is designed to avoid premature detection



Why this order matters

- EDA exposes the shape of normal activity before thresholds are chosen.
- Baselines prevent common events from being mislabeled as suspicious.
- Features translate raw rows into behavior that analysts can reason about.

The decision log explains why simpler choices won

Decision	Alternatives	Why rejected
Rule-based detection	Isolation Forest	No labels, lower explainability, harder SOC defense
Daily baseline	Weekly baseline	Dataset is too short for stable weekly seasonality
Failure rate	Raw failures	Normalizes activity across users and source volumes
IP velocity	Raw IP count	Makes source spread comparable across users
Behavioral features	Row-level flags	Security behavior emerges across event sequences

The strongest defense is not only what was chosen, but why tempting alternatives were not used first.

Baseline-first analysis keeps the investigation explainable

Question	Decision	Reasoning
Why EDA first?	Inspect normal behavior	Anomaly labels are meaningless without context.
Why not ML first?	Start with interpretable rules	No labels or ground truth exist in the assignment.
Why baseline before thresholds?	Estimate natural variance	Thresholds need a denominator and a normal range.
Why behavior over rows?	Engineer user/IP patterns	Attack behavior emerges across events, not one record.

The method is intentionally conservative: explainable evidence first, automation later.

The dataset is useful but missing key production signals

Records

10 158

2024-01-01 to 2024-03-29

Users

100

Known user identifiers

Fields

6 raw

Time, user, IP, device, network, outcome

Failure rate

6.2%

634 failed attempts

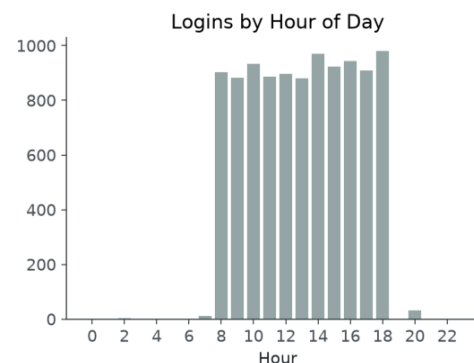
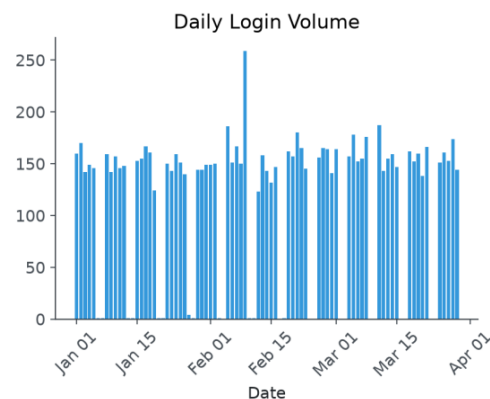
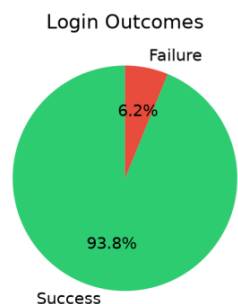
Available	Missing in production	Why it matters
Timestamp	Geo / ASN	Impossible travel and known bad infrastructure
User and IP	User agent / browser	Spoofing, bot signatures, device novelty
Device and network type	MFA status	Step-up failures and bypass attempts
Success flag	Session context	Post-login abuse and privilege changes

Data quality issues are small but operationally important

Issue	Count	Business impact	Action
Missing IP	3	Weakens IP-based detection	Investigate upstream source
Missing outcome	3	Affects failure metrics	Use conservative handling
Duplicates	88	Inflates alerts and velocity	Deduplicate before scoring
Invalid labels	2	Signals schema inconsistency	Normalize values at ingest

Even tiny integrity gaps matter because security alerts can become automated containment decisions.

EDA shows stable volume with visible failure spikes



What would concern me

- Overall outcomes are mostly successful, but failure spikes are not evenly distributed.
- Daily traffic is stable enough to make Feb 9 stand out.
- Hourly activity gives a normal-use reference for off-hours investigation.

The EDA job is to define where normal behavior ends before calling something suspicious.

Feb 9 is the clearest dataset-level authentication anomaly

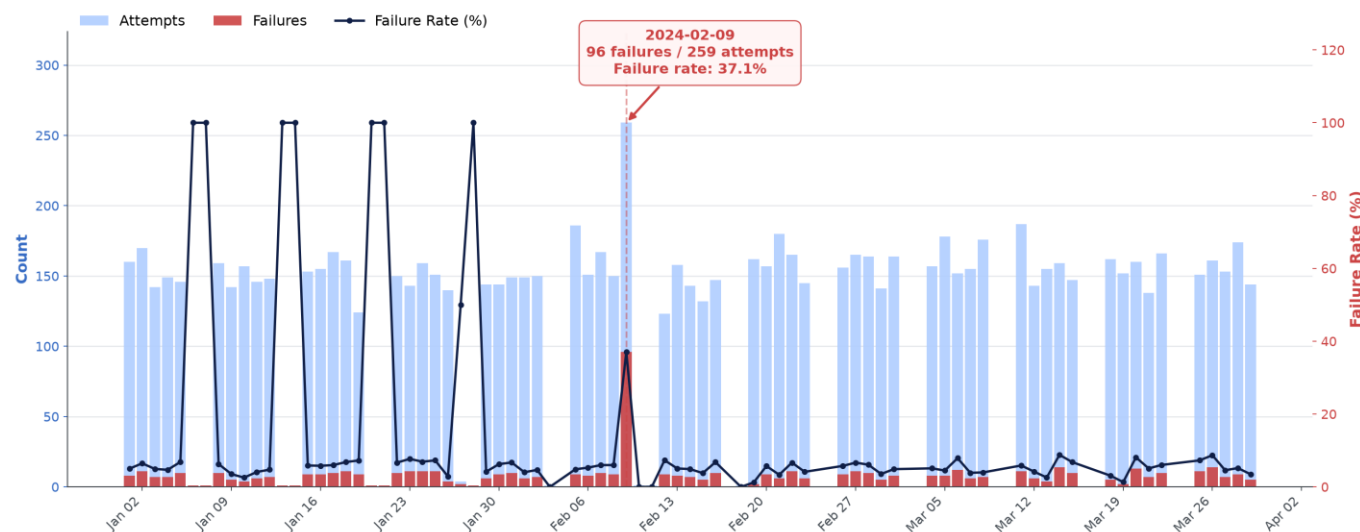
Daily Login Attempts and Failures

Total Attempts
10,158
Avg / day: 132

Total Failures
634
Avg / day: 8.2

Failure Rate
6.24%
Avg daily rate: 14.67%

Date Range
Jan 01 - Mar 29, 2024
77 days



Feb 9 attempts

259

Normal days are much lower

Feb 9 failures

96

Concentrated failure spike

Failure rate

37.1%

Versus baseline near single digits

The spike creates the need to move from aggregate trend to user/IP-level investigation.

Raw login rows become useful only after behavior is engineered

Feature	Definition	Analyst question
Failure rate	Failures / attempts	Is the account being guessed?
IP velocity	Unique IPs / attempts	Is traffic rotating across infrastructure?
Unique IP count	Distinct sources per user	Is access distributed or shared?
Attempt velocity	Attempts per time window	Is activity humanly plausible?
Off-hours flag	Login outside normal window	Is timing unusual for this user?
Composite risk	Weighted rule score	Which cases should SOC review first?

Feature engineering is the bridge between a notebook and an explainable risk signal.

Failure rate separates user mistakes from attack pressure

Definition: failed logins divided by total attempts for the same entity.

Business meaning

Password guessing pressure

Why it matters

Formula

failures / attempts

Notebook feature logic

Production version

**Track by user, IP, subnet,
device, and rolling time
window.**

Operational hardening

High failure rate is evidence, not proof; lockouts, password resets, and outages can mimic it.

IP velocity reveals distributed access patterns

Definition: unique IP addresses divided by total attempts.

Business meaning

Infrastructure rotation

Why it matters

Formula

$\text{unique_ips} / \text{attempts}$

Notebook feature logic

Production version

Compare against each user's historical baseline and ASN/geography.

Operational hardening

This dataset has high IP spread broadly, so the threshold needs calibration by population and user segment.

Unique IP count identifies accounts with unusually wide source spread

Definition: count of distinct source IPs by user.

Business meaning

Account sharing or botnet activity

Why it matters

Formula

nunique(ip)

Notebook feature logic

Production version

Normalize by active days, device consistency, ASN, and geography.

Operational hardening

Travel and VPN usage can inflate the count without being malicious.

Attempt velocity catches bursts no human can generate

Definition: attempts per second, minute, or short time window.

Business meaning

Automation and brute force

Why it matters

Formula

count in time bucket

Notebook feature logic

Production version

Use per-user, per-IP, and per-subnet rate limits with idempotent event IDs.

Operational hardening

Clock precision and duplicate ingestion must be validated before containment.

Off-hours access is a weak signal until combined with novelty

Definition: login outside expected working window.

Business meaning

Timezone or compromise clue

Why it matters

Formula

hour < 6 or outside profile

Notebook feature logic

Production version

Learn per-user temporal profiles and combine with new IP/device/MFA signals.

Signatures: Gardening

Remote teams, on-call work, and travel all create legitimate exceptions.

A daily baseline turns spikes into measurable deviations

Definition: normal daily attempts, failures, and failure rate.

Business meaning

**System-level incident
detection**

Why it matters

Formula

daily metric vs baseline

Notebook feature logic

Production version

**Use rolling windows,
seasonality, and
deployment calendars.**

Operational hardening

A static baseline breaks when seasonality, growth, or campaigns change behavior.

Composite risk should prioritize review, not replace judgment

Definition: interpretable weighted combination of behavioral signals.

Business meaning

SOC queue ranking

Why it matters

Formula

rule score

Notebook feature logic

Production version

Calibrate with analyst labels, alert outcomes, and false-positive monitoring.

Operational hardening

Weights can encode bias and stale assumptions if feedback is not captured.

The anomalies map to a threat kill chain



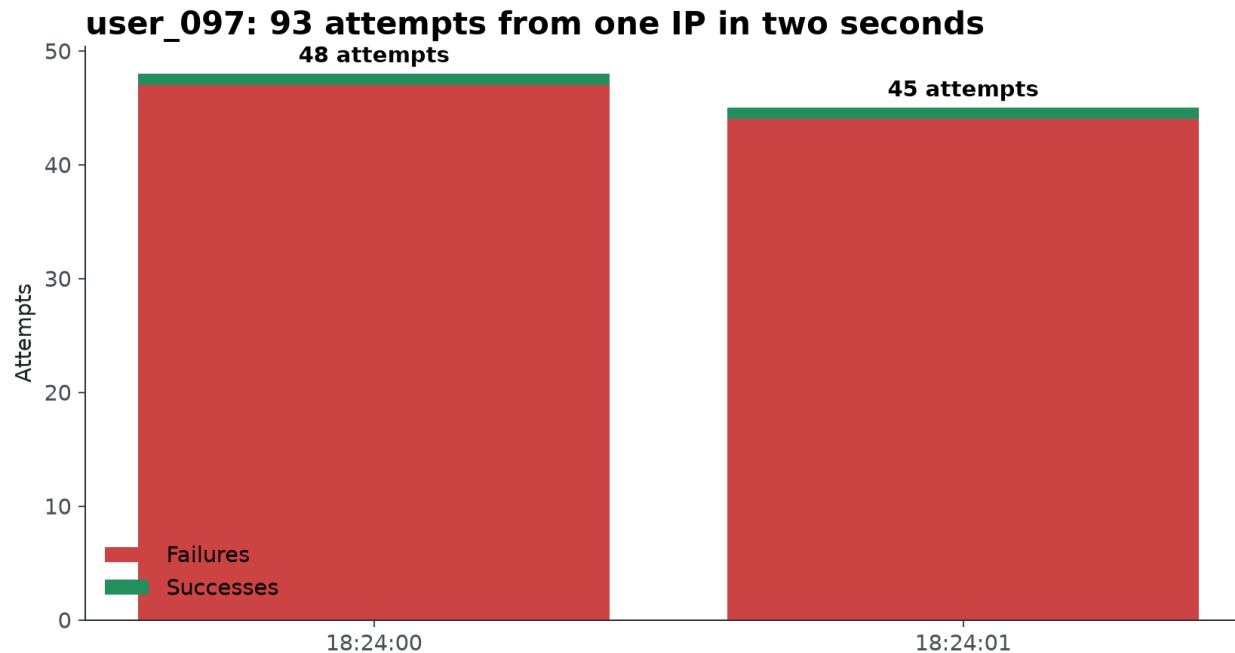
Stage	Observed anomaly	Why it matters
Password spray	20 users from one IP at one second	Single source testing many accounts
Credential stuffing	user_097 burst and user_003 probe	Automated guessing against known accounts
Successful login	13 successes in shared-IP event	Potential account compromise, not just attempts
Persistence / misuse	Off-hours access with high IP spread	Possible post-compromise access pattern

Mapping anomalies to attack stages shows what to contain first and what telemetry is missing next.

Anomaly 1: user_097 shows an automated brute-force burst

CONFIDENCE 95%

CRITICAL



Evidence

- 48 attempts at 2024-02-09 18:24:00 from 103.56.23.138.
- 97 failures across 194 logins for a 50.0% failure rate.
- The timing pattern is not physically plausible for a human user.

Alternative explanations

- Duplicated logs
- Replay artifact

Remaining uncertainty

- No event ID for dedupe
- No ASN or infrastructure metadata

Immediate response: force reset for user_097, block or rate-limit the source IP, and inspect nearby successful sessions.

Anomaly 2: user_003 was probed on a machine schedule

CONFIDENCE 90%

CRITICAL

Evidence

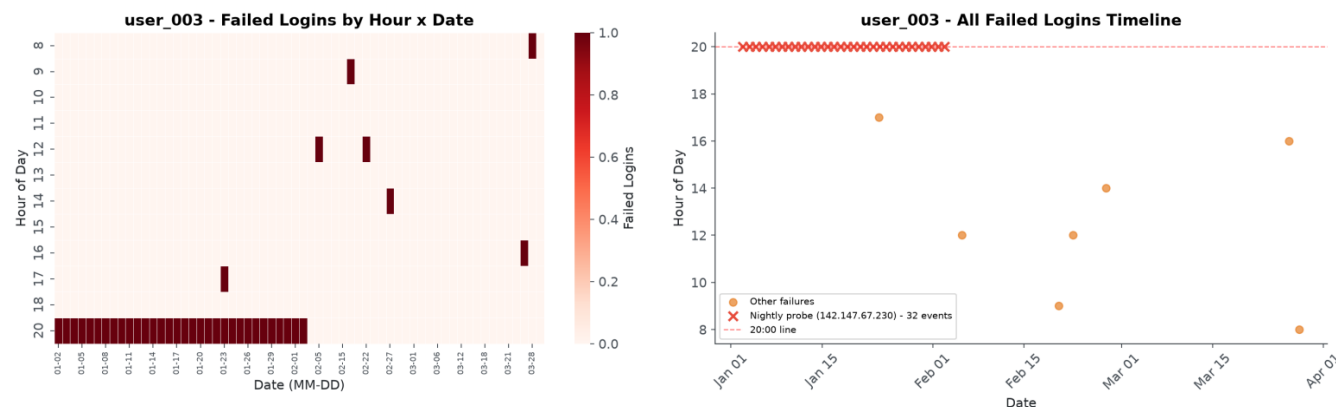
- 33 attempts from 142.147.67.230 at exactly 20:00.
- 32 failures followed by 1 success.
- 93 unique IPs make account-level exposure unusually broad.

Alternative explanations

- Scheduled service account
- Synthetic test artifact

Remaining uncertainty

- No account owner context
- No geo, ASN, or user-agent data



Immediate response: block 142.147.67.230, rotate credentials, and check whether the final success changed account state.

Anomaly 3: one IP touched 20 users at the exact same second

CONFIDENCE 92%

CRITICAL

Evidence

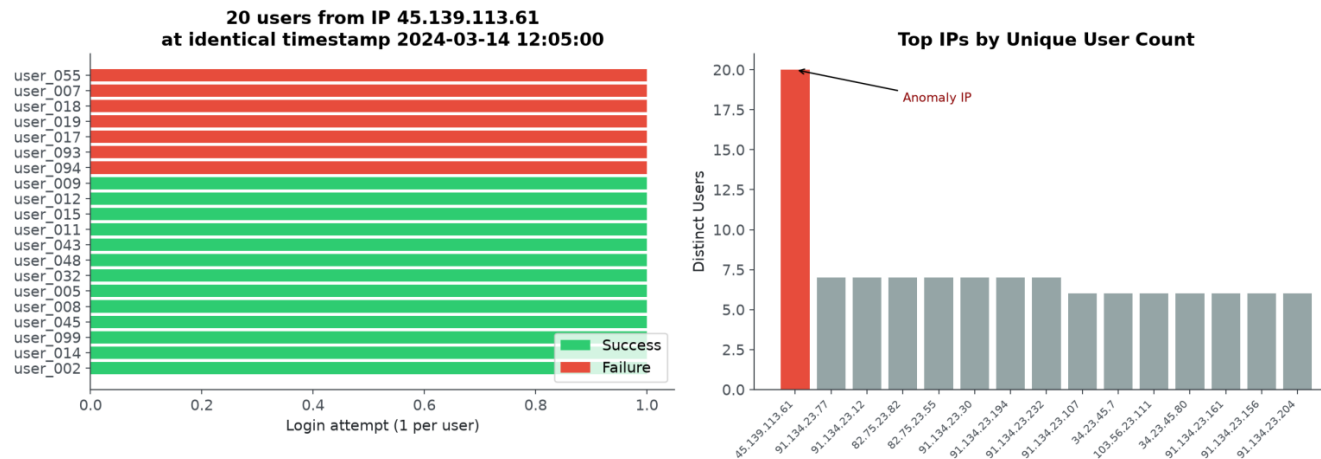
- 20 users from 45.139.113.61 at 2024-03-14 12:05:00.
- 7 failures and 13 successes in the same timestamp group.
- The pattern fits spray, replay, proxy, or controller behavior.

Alternative explanations

- Corporate NAT or VPN exit
- Load-test replay

Remaining uncertainty

- No ASN reputation
- No session IDs after login



Immediate response: block the IP, enumerate affected users, and review all successful sessions from that source.

Anomaly 4: IP velocity is useful but the threshold needs calibration

CONFIDENCE 70%

HIGH

Evidence

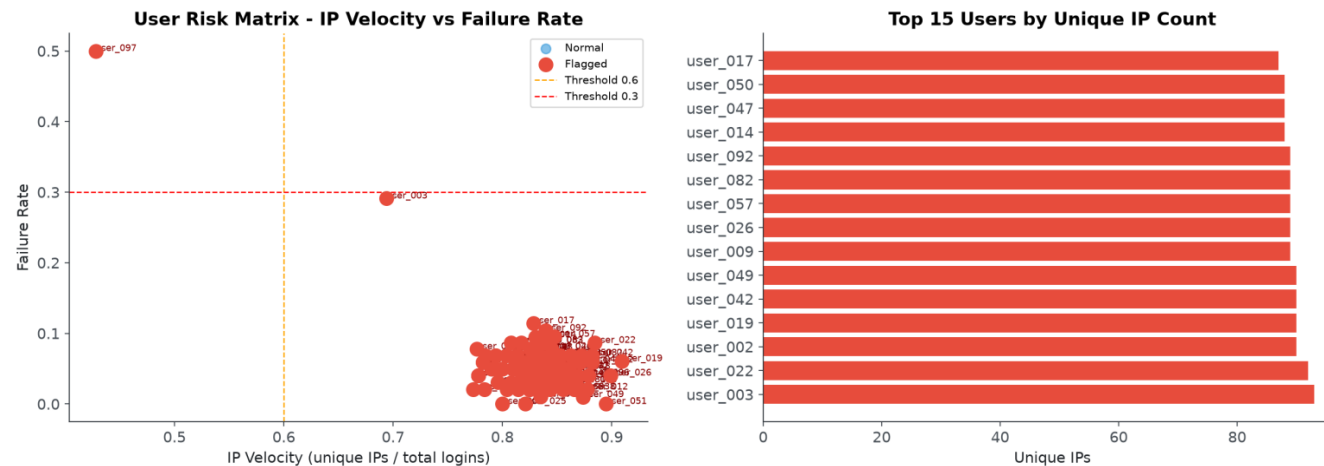
- The notebook rule flags the population broadly, which is a signal that the threshold is too naive for this dataset.
- user_003 still stands out with 93 unique IPs across 134 sessions.
- The right production version compares users to their own historical baselines.

Alternative explanations

- VPN-heavy user population
- Synthetic IP distribution

Remaining uncertainty

- Threshold not calibrated
- No geo, ASN, or historical profile



Action: keep IP velocity as a feature, but calibrate it with geography, ASN, device stability, and analyst feedback.

Anomaly 5: off-hours access becomes material when paired with other risk

CONFIDENCE 65%

MEDIUM

Evidence

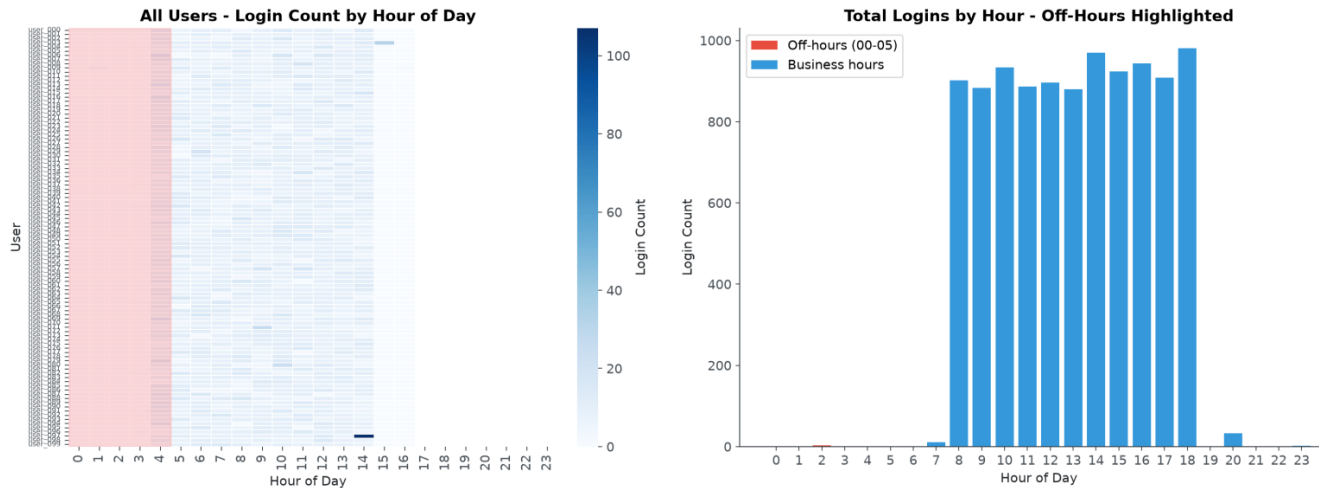
- 5 total midnight-to-05:00 logins appear in the dataset.
- user_009 contributes 4 of them.
- user_009 also shows 89 unique IPs, making timing more concerning.

Alternative explanations

- Legitimate timezone
- On-call or travel access

Remaining uncertainty

- No user work schedule
- No timezone or geo data



Action: treat off-hours as a multiplier, not a standalone block condition; require novelty and user profile context.

The investigation should rank cases by evidence and actionability

Anomaly	Confidence	Entity	Reason
Brute-force burst	95%	user_097	48 attempts at one second; 50.0% failure rate
Nightly probe	90%	user_003	33 exact 20:00 attempts from one IP
Shared IP spray	92%	45.139.113.61	20 users at same timestamp; 7 failures
IP velocity	70%	100 users	Threshold flags broad behavior; needs calibration
Off-hours access	65%	user_009	4 midnight-to-05:00 logins plus high IP spread

The SOC queue should start with automated bursts and mass shared-IP events because they are high-confidence and easy to contain.

These findings are evidence, not courtroom proof

Risk to manage	How it appears here	Mitigation
False positives	VPNs, travel, failed password memory	Use combinations of signals and analyst review
False negatives	Low-and-slow attacks below thresholds	Monitor sequences and rolling baselines
Sampling bias	Only three months and no labels	Backtest on longer historical periods
Threshold bias	IP velocity flags too broadly	Calibrate per user segment and feedback
Missing context	No geo, ASN, MFA, user agent	Enrich events before automation

The correct claim is 'high-confidence suspicious behavior requiring investigation,' not confirmed malicious activity.

Heuristics are the right first model for this unlabeled dataset

Approach	Interpretability	Data need	Maintenance	Fit here
Heuristics	High	Low	Low	Best starting point
Isolation Forest	Medium	Medium	Medium	Possible after baselines
LOF / DBSCAN	Medium	Medium	Medium	Useful for clusters
Random Forest	Medium	High labels	Medium	Needs outcomes
Sequence models	Low	High	High	Future stage
Deep learning	Low	Very high	High	Not justified now

Explainability matters because security operations must defend every alert and containment action.

Explainability is what makes detection operational

Why it matters	Security impact	How heuristics help
Analyst trust	SOC teams need to understand why a case fired	Rules expose the exact signal
SOC acceptance	Opaque scores are harder to act on quickly	Evidence is readable in the queue
Legal defensibility	Containment decisions may need audit trails	Thresholds and data inputs are explicit
Threshold tuning	False positives must be reduced without hiding risk	Each rule can be adjusted separately
Incident learning	Close reasons should improve the detector	Feedback maps back to individual features

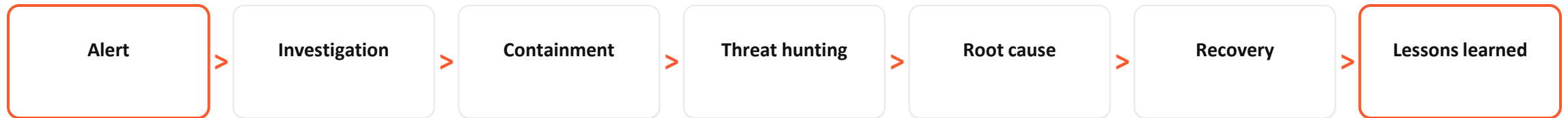
Heuristics are not less sophisticated here; they are the explainable control layer that earns permission to automate.

Operational cost favors heuristics before ML

Dimension	Heuristics	Machine learning
Latency	Milliseconds; simple rule evaluation	Higher and variable with feature joins and inference
Infrastructure	Minimal; stream rules and dashboards	Feature pipelines, model serving, registry, monitoring
Maintenance	Low to medium; tune thresholds	Retraining, drift detection, version governance
Explainability	High; direct evidence	Depends on model and explanation layer
Cost risk	Alert fatigue if rules are broad	Inference cost plus silent drift if not monitored

The right sequence is low-cost, interpretable protection first, then ML once labels and feedback justify the operating burden.

The analysis fits inside a SOC investigation loop



Notebook output	SOC action	Operational artifact
Ranked anomalies	Open cases by severity	Alert queue
Evidence charts	Validate behavior	Case timeline
Recommended response	Contain affected accounts	SOAR playbook
Limitations	Avoid over-blocking	Analyst notes

Dashboard charts should answer decisions, not decorate the page

Widget	Question answered	Decision enabled
Failure rate	Is authentication degrading?	Investigate outage or attack
Unique IPs	Is access distributed?	Escalate stuffing investigation
New device/IP	Is account behavior novel?	Trigger step-up MFA
Hourly heatmap	Is timing abnormal?	Contextualize alert confidence
Top entities	Who needs review first?	Prioritize SOC queue

Every dashboard element should point to a user, threshold, refresh cadence, drilldown, and business action.

The assignment has two equal analytical products

Security analytics



- Primary user: SOC analyst
- Decision: contain, investigate, or monitor
- Success metric: high-confidence risk reduction

Product analytics



- Primary user: product and growth leader
- Decision: scale, investigate, or fix tracking
- Success metric: durable high-quality growth

Both halves ask the same senior question: what decision changes when the metric moves?

The KPI dashboard separates growth from account quality

New Customer Sign-Ups - KPI Monitoring Dashboard

Red shading = surge period (Mar 25+) | Quality drop-off during spike

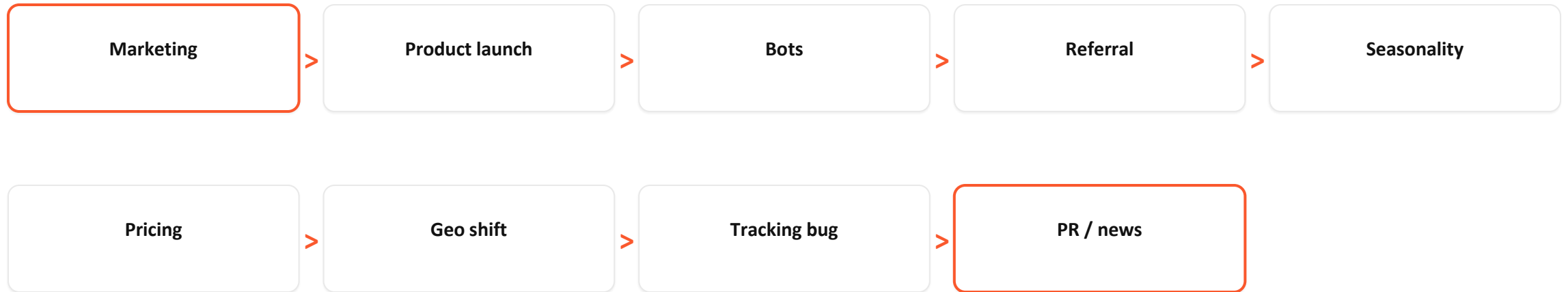


Walkthrough logic

- Sign-up spikes are not automatically good news.
- Channel, geography, verification, activation, and paid conversion reveal quality.
- Surge-period shading helps separate timing from metric movement.

The same investigation mindset applies to product analytics: explain the movement before celebrating it.

A sign-up spike needs a hypothesis tree before a dashboard verdict



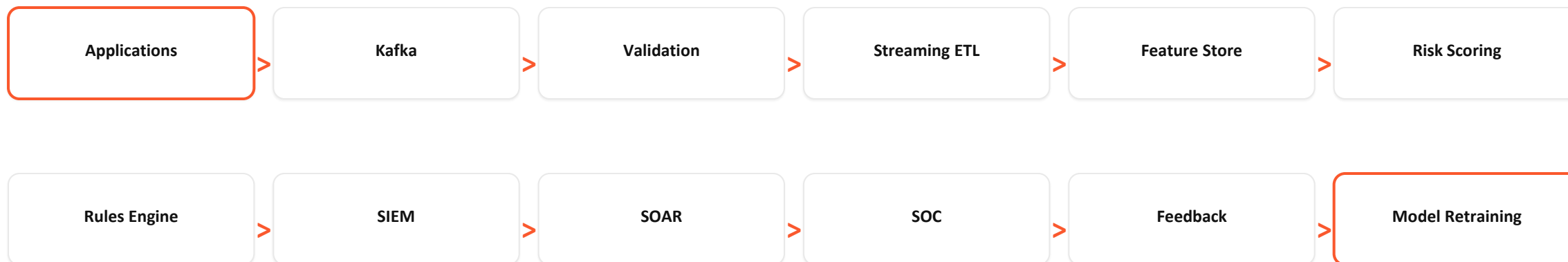
Hypothesis	How to eliminate it	Metric to inspect
Marketing campaign	Match spend and campaign launch dates	Channel mix, CAC
Bot or spam	Check verification and activation quality	Verify rate, device/IP reuse
Tracking bug	Reconcile raw events with warehouse	Duplicate rate, schema change
Geo or referral shift	Segment by geography and source	Country, referrer, conversion

The KPI framework must measure both volume and quality

Metric	Purpose	Quality lens
Signups	Top-of-funnel volume	Unique accounts, dedupe
Verification	Identity and intent	Email/SMS completion rate
Activation	Product value reached	First meaningful action
Retention	Sustained usefulness	D1/D7/D30 cohorts
CAC / channel	Efficiency	Paid versus organic quality
Referral / geo	Source of movement	Fraud, localization, PR

Volume metrics need quality companions, or growth can mask abuse.

Production architecture turns notebook logic into governed detection



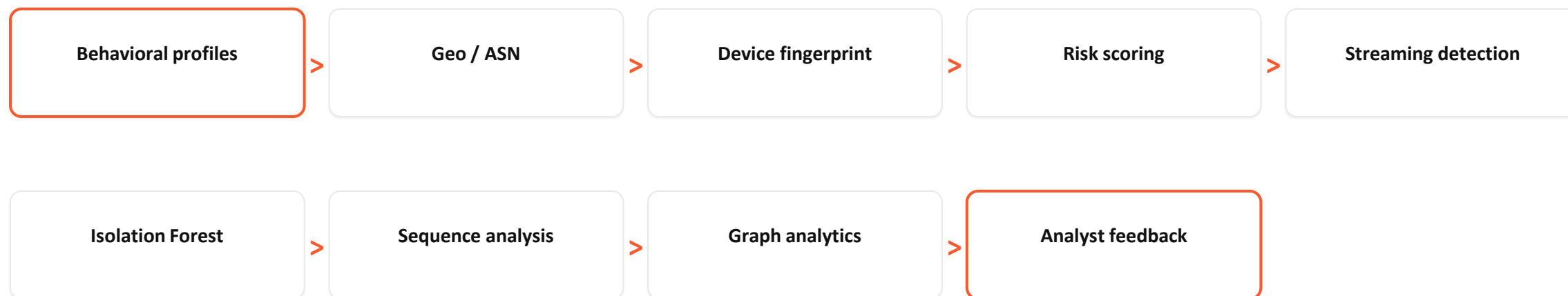
Design principles

- Validation prevents bad labels, missing IPs, and duplicate events from becoming false alerts.
- Feature Store keeps notebook, batch, and streaming definitions consistent.
- Rules Engine makes the first detection layer explainable before ML is added.
- SOC feedback feeds threshold tuning today and model retraining later.

Production monitoring must cover the detector, not just the data

Monitor	Failure mode	Action
Data quality	Missing IP, bad labels, duplicates	Block deployment or quarantine events
Latency	Alerts arrive too late	Scale streaming path
Schema drift	Fields change silently	Contract tests and alerts
Concept drift	Normal behavior changes	Recalibrate thresholds
Alert fatigue	Too many low-value alerts	Track precision and close reasons
Pipeline failures	Gaps in coverage	SLOs and replay capability

A one-month build should enrich context before adding complex ML



The highest-leverage improvement is enrichment plus calibrated behavioral profiles; advanced ML comes after labels and feedback exist.

The main limitations are context, labels, and production

Limitation	Impact	How to reduce it
No labels	Cannot estimate precision or recall	Use analyst feedback and confirmed incidents
No geo / ASN	IP velocity can be misleading	Enrich IPs and subnet reputation
No browser / UA	Device spoofing is invisible	Collect user-agent and fingerprint signals
Limited time span	Seasonality unknown	Backtest longer periods
Synthetic thresholds	Rules may over-alert	Calibrate per segment
Notebook analysis	Not a production control	Move to governed pipeline

The assignment demonstrates four senior analyst habits

Business

Frame risk

Not rows

Technical

**Engineer
behavior**

Not raw fields

Security

Think SOC

Not only charts

Product

**Measure
quality**

Not only volume

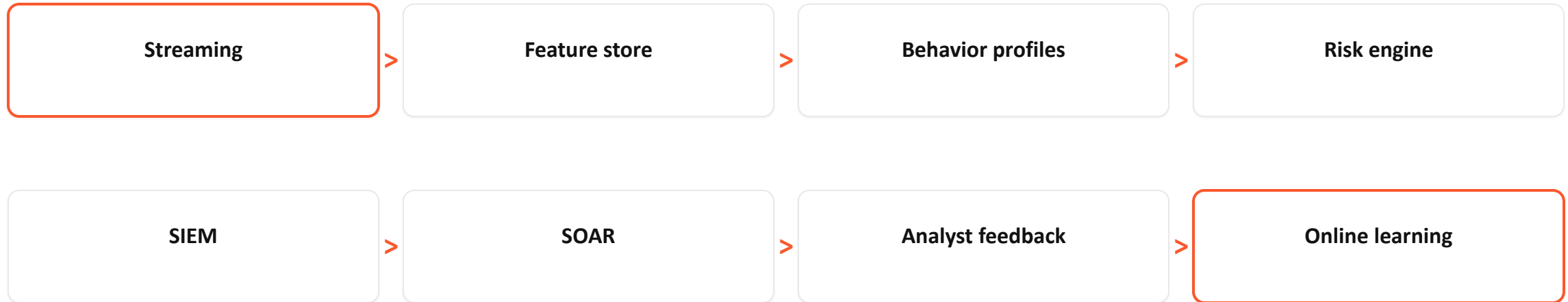
Lessons learned

- The same pattern applies across login security and product KPI investigation.
- A good answer makes assumptions visible and testable.
- The end product is a decision system, not a notebook screenshot.

Recommended actions move from containment to platform maturity

Horizon	Action	Owner
Immediate	Block confirmed malicious IPs; reset user_097 and user_003; rate-limit bursts	SOC / IAM
Immediate	Review successful sessions from shared IP 45.139.113.61	SOC
Short term	Add MFA, geo checks, ASN, user-agent, and session telemetry	Security engineering
Medium term	Create behavioral risk scoring and calibrated dashboards	Analytics / detection
Long term	Move to streaming detection with analyst feedback and model governance	Platform

At Palo Alto scale, this becomes an enterprise security analytics platform



The assignment can evolve into a high-trust detection platform when feature definitions, feedback, and operations are treated as product surfaces.

The final story: explainable, defensible, extensible detection

This investigation demonstrates a repeatable analytical framework rather than a collection of isolated findings. I intentionally prioritized interpretable behavioral analytics over more complex machine-learning approaches because the dataset lacked labels and production context. The proposed features, investigation workflow, and dashboard are designed to support security analysts today while providing a clear path toward a production-grade detection platform through enrichment, feedback loops, and gradual automation.

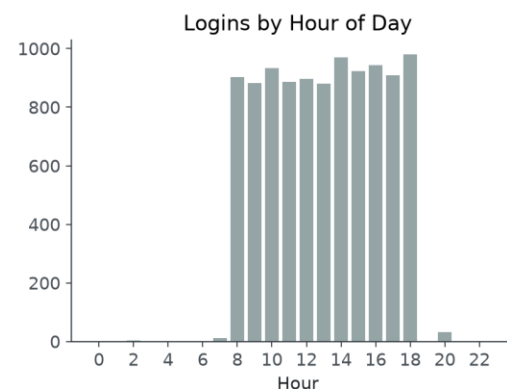
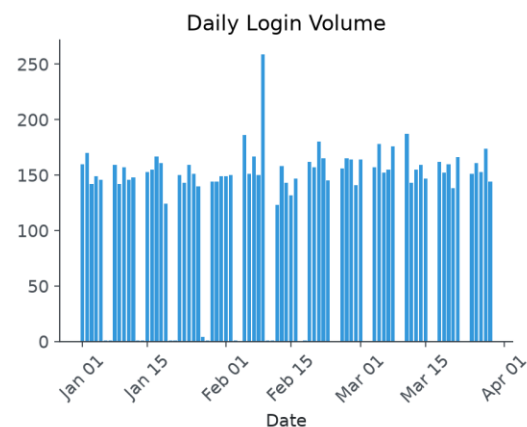
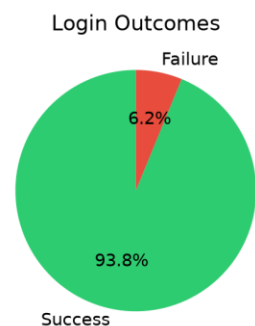
The goal is not simply to detect suspicious events; it is to design an analytical process that is explainable, defensible, and extensible.

Appendix

Backup evidence, formulas, SQL equivalents, implementation notes,
and interview defense material

A1. Dataset overview visual

Backup visual from the provided notebook/script



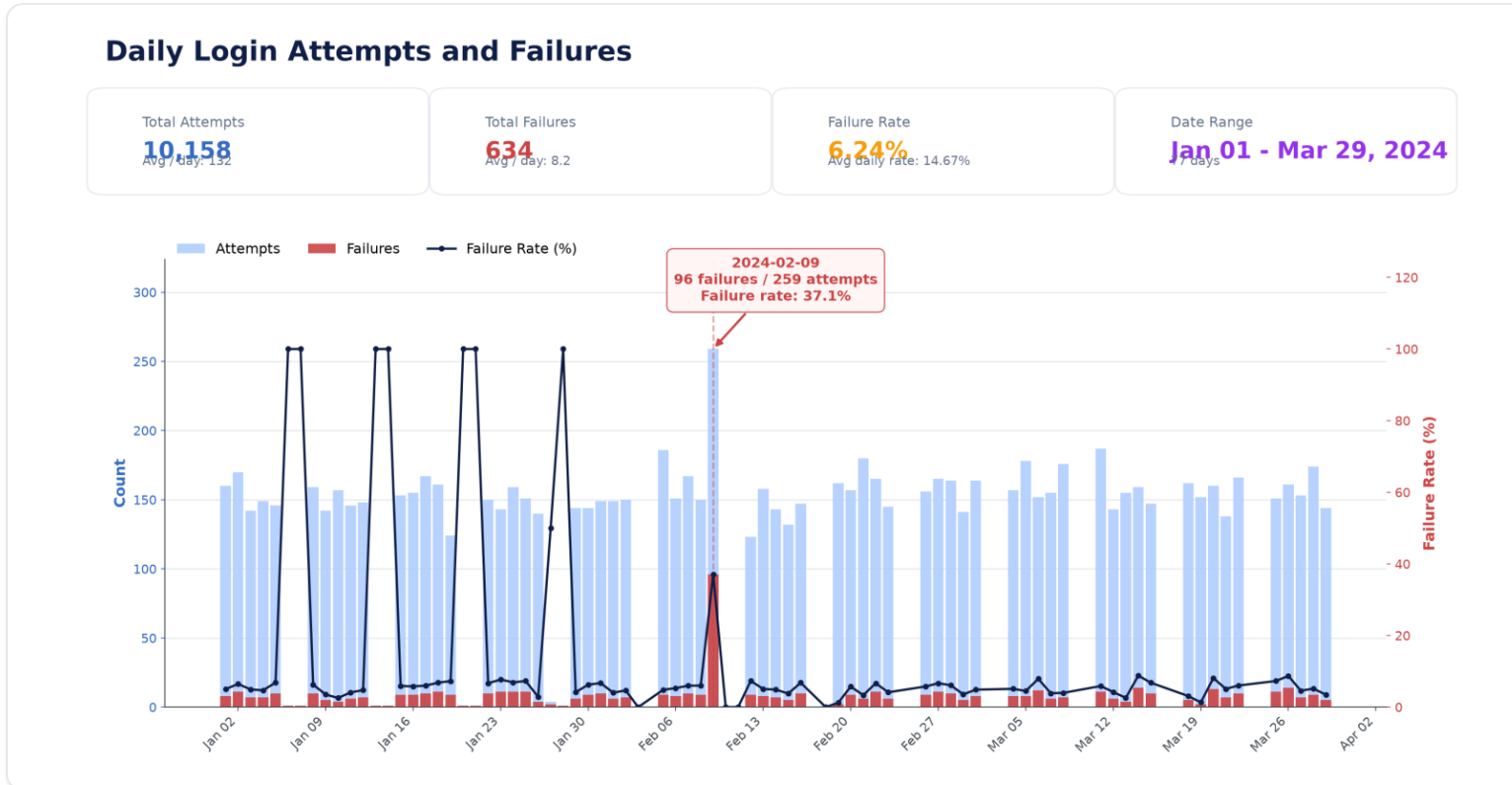
Defense points

- Shows success/failure mix, daily volume, and hourly distribution.
- Useful for proving the analysis starts with normal behavior.
- The chart is exploratory, not a detector.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A2. Baseline daily attempts and failures

Backup visual from the provided notebook/script



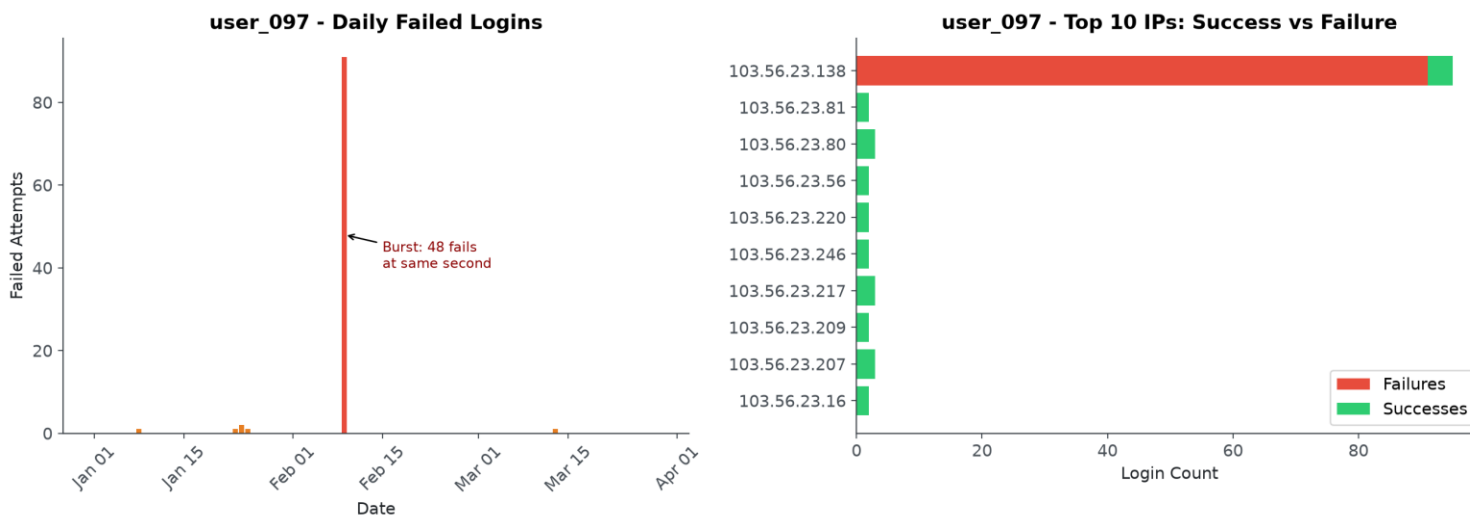
Defense points

- The Feb 9 spike is the clearest aggregate anomaly.
- The daily baseline is stable enough to support investigation.
- Failure rate is more meaningful than raw failures alone.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A3. user_097 brute-force evidence

Backup visual from the provided notebook/script



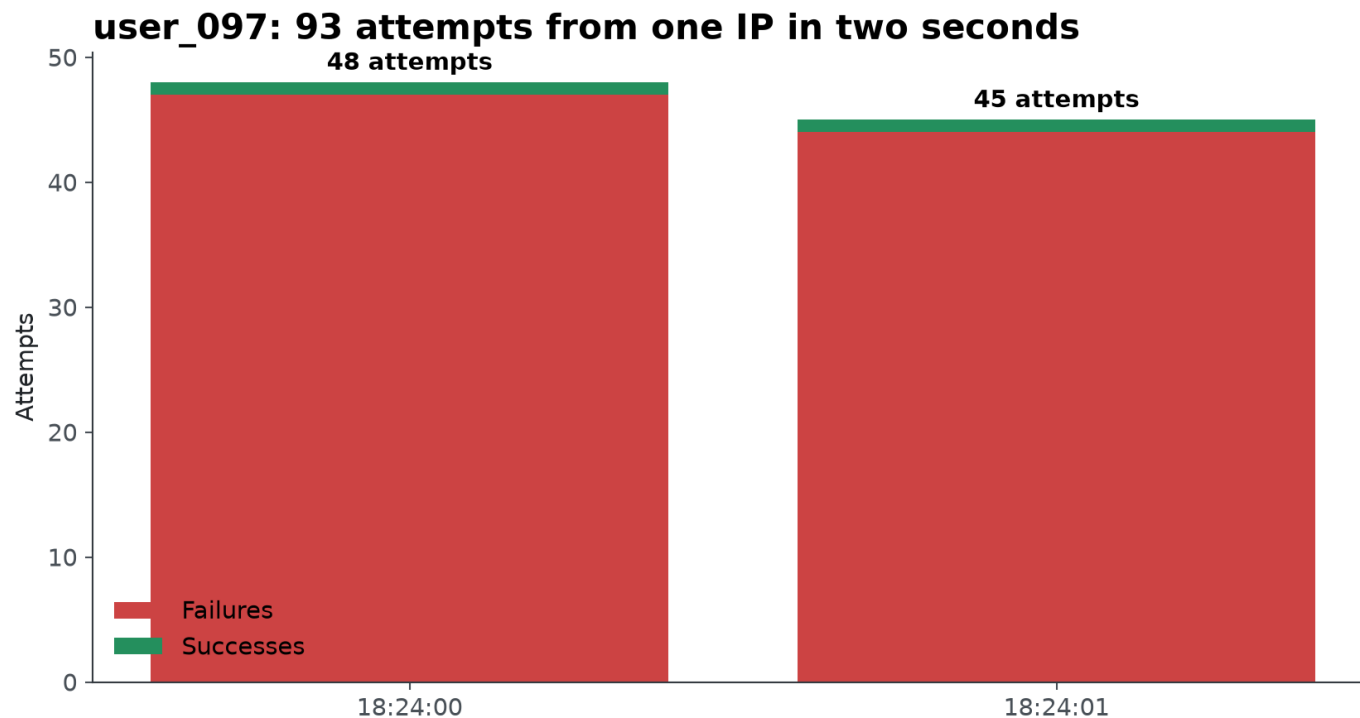
Defense points

- The same user and IP dominate the failure burst.
- Daily view shows concentration on Feb 9.
- IP breakdown supports targeted containment.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A4. user_097 two-second burst

Backup visual from the provided notebook/script



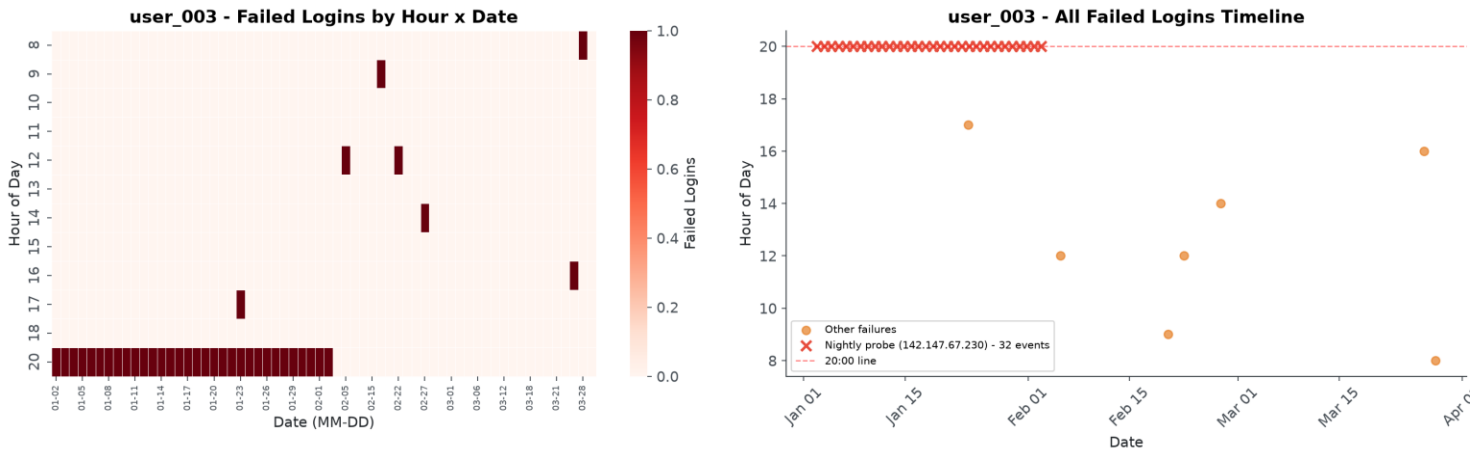
Defense points

- The exact timestamp burst is machine-like.
- This is higher confidence than generic high failure rate.
- Duplicate ingestion should still be checked before automation.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A5. user_003 nightly probe heatmap

Backup visual from the provided notebook/script



Defense points

- The 20:00 cadence is the key signal.
- A scheduled job explanation is more plausible than human behavior.
- Final success makes account review urgent.

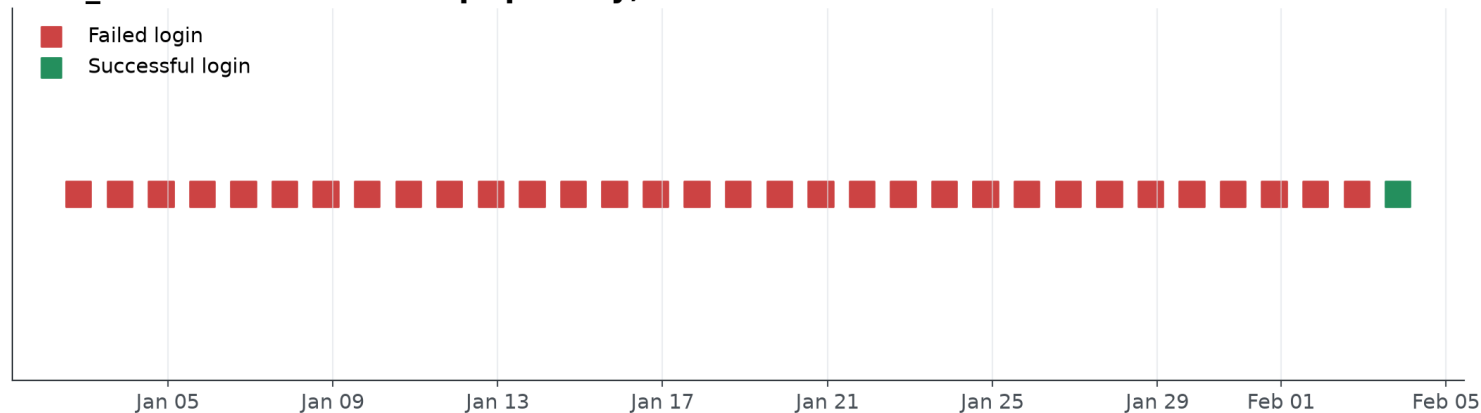
Use this slide only when the interviewer wants the detail behind the main-story claim.

A6. user_003 low-and-slow timeline

Backup visual from the provided notebook/script

user_003: one 20:00 attempt per day; 32 failures then success

■ Failed login
■ Successful login



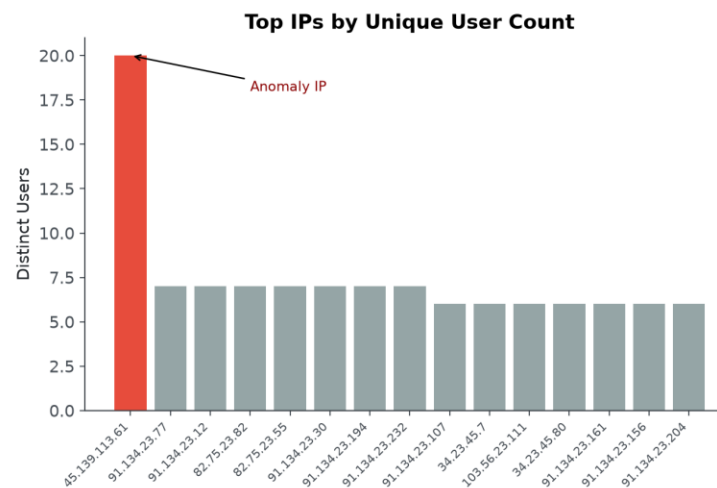
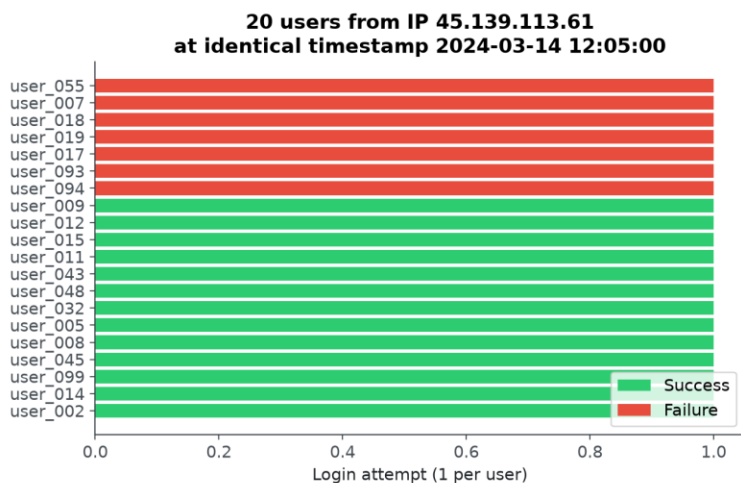
Defense points

- The pattern avoids high-velocity thresholds.
- Sequence logic is needed for low-and-slow attacks.
- A single success after repeated failures changes risk.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A7. Shared IP multi-user event

Backup visual from the provided notebook/script



Defense points

- One IP touching many users at the same second is high-confidence.
- Successes and failures together suggest partial compromise or replay.
- This is a strong candidate for blocking and user enumeration.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A8. Shared IP user outcome detail

Backup visual from the provided notebook/script

IP 45.139.113.61: 20 users at the exact same timestamp

user_002	success
user_005	success
user_008	success
user_009	success
user_011	success
user_012	success
user_014	success
user_015	success
user_032	success
user_043	success
user_045	success
user_048	success
user_099	success
user_007	failed
user_017	failed
user_018	failed
user_019	failed
user_055	failed
user_093	failed
user_094	failed

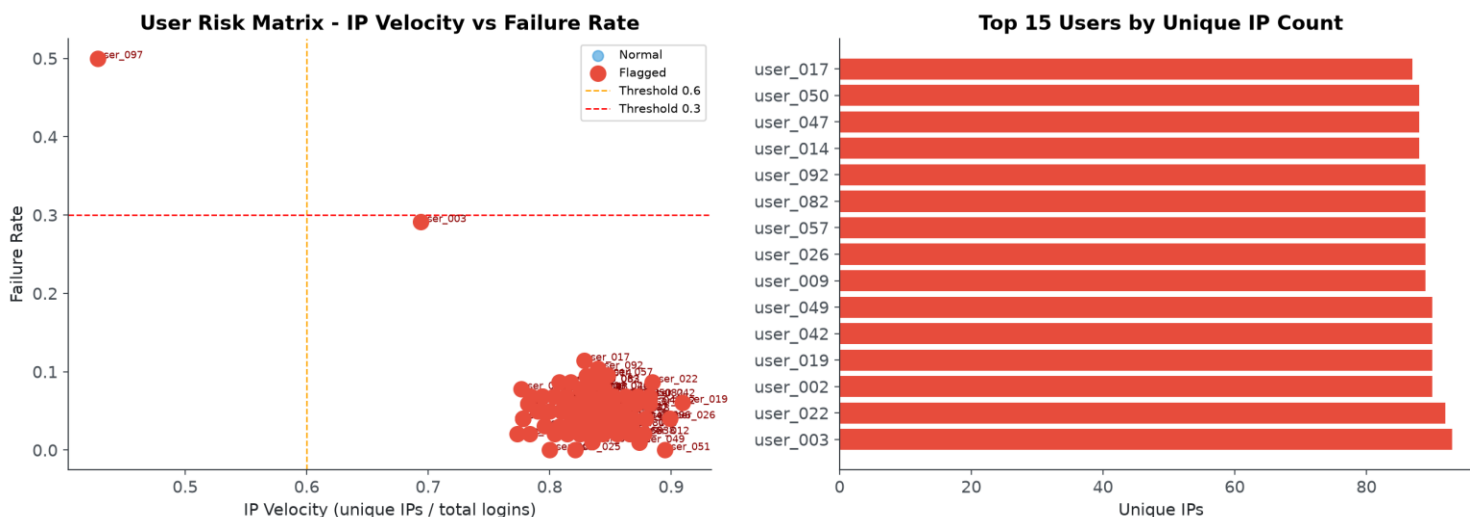
Defense points

- The visual identifies affected users.
- Green successes are investigation targets, not reassurance.
- Containment should review post-login activity.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A9. IP velocity risk matrix

Backup visual from the provided notebook/script



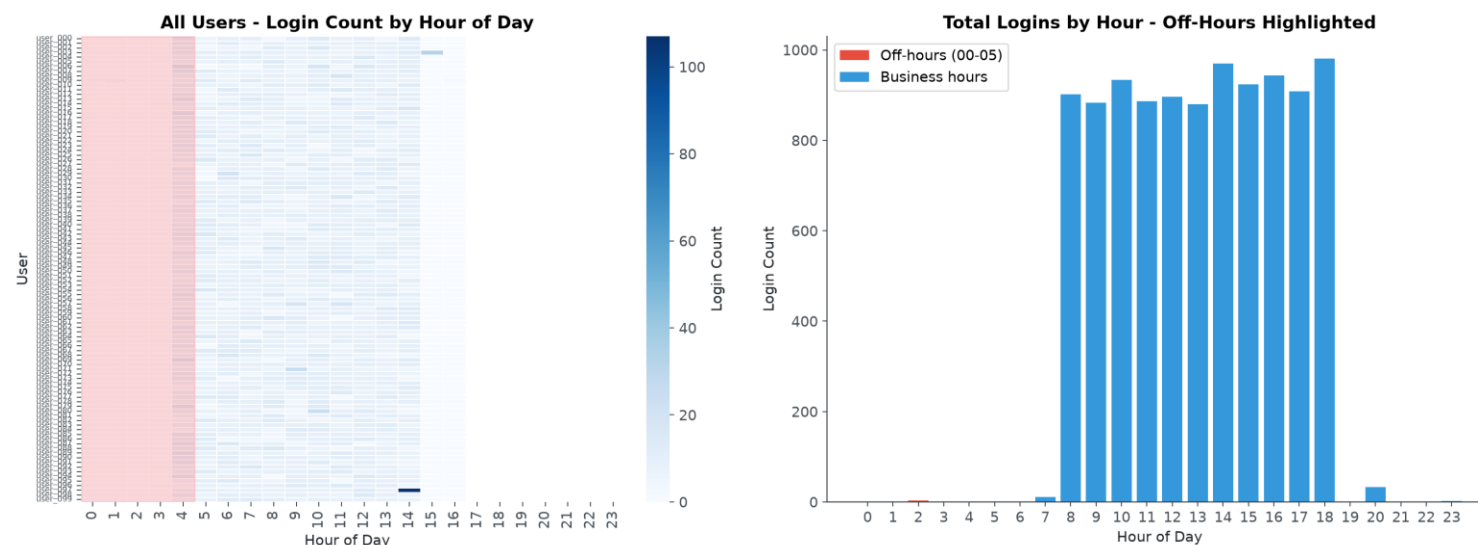
Defense points

- The feature is useful, but the broad threshold over-flags.
- This is a threshold calibration lesson.
- Use historical baselines and enrichment in production.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A10. Off-hours access visual

Backup visual from the provided notebook/script



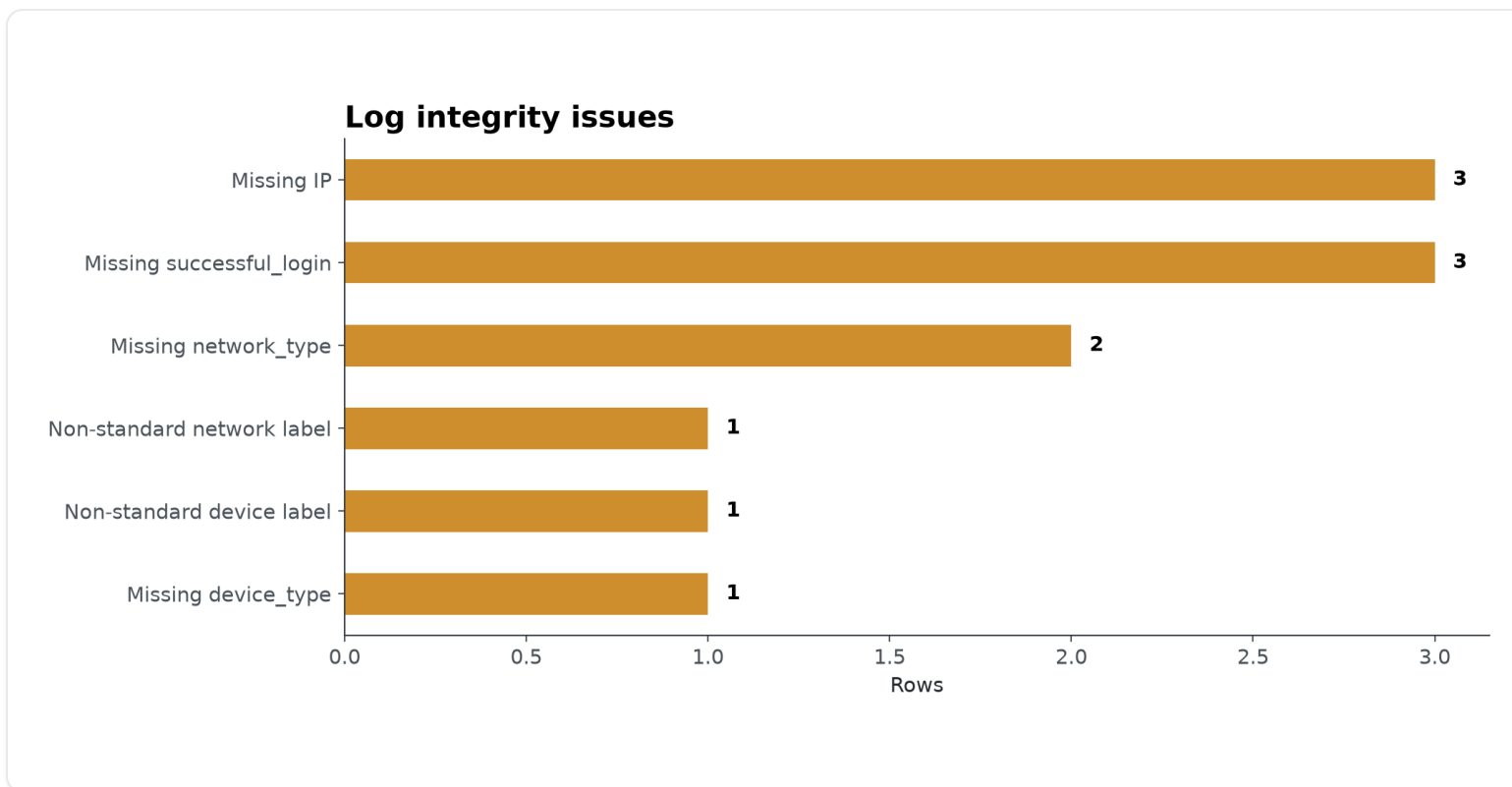
Defense points

- Off-hours is weak alone but useful as a risk multiplier.
- user_009 is interesting because timing combines with high IP spread.
- Timezone context would reduce false positives.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A11. Log integrity visual

Backup visual from the provided notebook/script



Defense points

- Quality issues are small in count but large in security impact.
- Missing IP breaks source-based rules.
- Schema validation belongs in production monitoring.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A12. Product KPI dashboard visual

Backup visual from the provided notebook/script



Defense points

- The dashboard asks whether a signup spike is healthy.
- Quality metrics prevent over-celebrating volume.
- The same investigative pattern applies to product analytics.

Use this slide only when the interviewer wants the detail behind the main-story claim.

A13. Feature defense: Failure rate

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Failure rate	failures / attempts	Password guessing	Tune by user and IP window
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A14. Feature defense: IP velocity

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
IP velocity	unique IPs / attempts	Proxy or botnet rotation	Normalize by history and ASN
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A15. Feature defense: Unique IP count

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Unique IP count	nunique(ip)	Wide source spread	Normalize by active days
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A16. Feature defense: Attempt velocity

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Attempt velocity	count / time bucket	Automation burst	Deduplicate event IDs first
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A17. Feature defense: Off-hours

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Off-hours	hour outside profile	Timezone or compromise clue	Combine with novelty
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A18. Feature defense: Daily baseline

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Daily baseline	rolling daily metrics	System-level anomaly	Seasonality-aware windows
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A19. Feature defense: Composite risk

Definition, rationale, and production hardening

Feature	Notebook formula	Signal	Production note
Composite risk	weighted features	SOC prioritization	Calibrate with feedback
False-positive check	Review alternatives	Avoid over-blocking	Require analyst feedback

A20. Threshold rationale

Risk controls and caveats

- Start with interpretable thresholds because the dataset has no labels.
- Validate thresholds against known baselines before alerting.
- Treat broad flags as evidence that calibration is needed.
- Thresholds should rank review priority before they automate containment.

Thresholds should rank review priority before they automate containment.

A21. Assumptions to disclose

Risk controls and caveats

- The notebook treats missing successful_login as failure after initial inspection.
- Dates are interpreted in the source timestamp timezone because no user timezone exists.
- IP velocity is considered suspicious only when paired with other context.
- No malicious label is assumed without SOC confirmation.

No malicious label is assumed without SOC confirmation.

A22. Alternative explanations

Risk controls and caveats

- VPN use can create many IPs.
- Travel and on-call work can create off-hours logins.
- Application outage can create repeated failures.
- Duplicate ingestion can mimic impossible velocity.

Duplicate ingestion can mimic impossible velocity.

A23. Additional data needed

Risk controls and caveats

- Geo, city, and ASN for impossible travel and risky infrastructure.
- User-agent and browser fingerprint for spoofing and automation.
- MFA status and failure reason for attack-stage diagnosis.
- Session duration and post-login actions for account takeover confirmation.

Session duration and post-login actions for account takeover confirmation.

A24. Patterns to monitor next

Risk controls and caveats

- Password spray by subnet or ASN.
- Dormant account sudden activity.
- New device plus new IP plus off-hours.
- Successful login followed by sensitive account changes.

Successful login followed by sensitive account changes.

A25. SQL: daily login baseline

SQL equivalent for defending pandas transformations

```
SELECT
  CAST(datetime AS DATE) AS login_date,
  COUNT(*) AS attempts,
  SUM(CASE WHEN successful_login = 0 THEN 1 ELSE 0 END) AS failures,
  AVG(CASE WHEN successful_login = 0 THEN 1.0 ELSE 0.0 END) AS failure_rate
FROM login_events
GROUP BY CAST(datetime AS DATE)
ORDER BY login_date;
```

This is the SQL counterpart to the notebook's daily baseline table.

A26. SQL: user-level risk features

SQL equivalent for defending pandas transformations

```
SELECT
  user,
  COUNT(*) AS total_attempts,
  COUNT(DISTINCT ip) AS unique_ips,
  SUM(CASE WHEN successful_login = 0 THEN 1 ELSE 0 END) AS failures,
  1.0 * SUM(CASE WHEN successful_login = 0 THEN 1 ELSE 0 END) / COUNT(*) AS fail_rate,
  1.0 * COUNT(DISTINCT ip) / COUNT(*) AS ip_velocity
FROM login_events
GROUP BY user;
```

This makes the notebook feature engineering auditable in a warehouse.

A27. SQL: per-second burst detection

SQL equivalent for defending pandas transformations

```
SELECT
  user,
  ip,
  datetime,
  COUNT(*) AS attempts,
  SUM(CASE WHEN successful_login = 0 THEN 1 ELSE 0 END) AS failures
FROM login_events
GROUP BY user, ip, datetime
HAVING COUNT(*) >= 10
ORDER BY attempts DESC;
```

Use this to catch humanly impossible bursts like user_097.

A28. SQL: shared-IP spray detection

SQL equivalent for defending pandas transformations

```
SELECT
  ip,
  datetime,
  COUNT(*) AS attempts,
  COUNT(DISTINCT user) AS distinct_users,
  SUM(CASE WHEN successful_login = 0 THEN 1 ELSE 0 END) AS failures
FROM login_events
GROUP BY ip, datetime
HAVING COUNT(DISTINCT user) >= 10
ORDER BY distinct_users DESC;
```

This captures one IP touching many users in the same instant.

A29. SQL: off-hours candidates

SQL equivalent for defending pandas transformations

```
SELECT
  user,
  COUNT(*) AS offhour_logins,
  COUNT(DISTINCT ip) AS unique_ips
FROM login_events
WHERE EXTRACT(HOUR FROM datetime) BETWEEN 0 AND 5
GROUP BY user
ORDER BY offhour_logins DESC, unique_ips DESC;
```

Off-hours should be combined with novelty and account history.

A30. SQL: data quality checks

SQL equivalent for defending pandas transformations

```
SELECT 'missing_ip' AS check_name, COUNT(*) AS rows FROM login_events WHERE ip IS NULL
UNION ALL
SELECT 'missing_device_type', COUNT(*) FROM login_events WHERE device_type IS NULL
UNION ALL
SELECT 'missing_network_type', COUNT(*) FROM login_events WHERE network_type IS NULL
UNION ALL
SELECT 'missing_successful_login', COUNT(*) FROM login_events WHERE successful_login IS NULL;
```

Production alerting needs quality checks before scoring.

A31. Stream processing implementation

Implementation detail

- Parse login events with schema validation.
- Compute rolling counts by user, IP, ASN, subnet, and device.
- Emit both raw signals and composite risk score.
- Store all feature versions for auditability.

Store all feature versions for auditability.

A32. Feature store design

Implementation detail

- Offline and online features must share definitions.
- Keys should include user, IP, subnet, device, and time window.
- Backfills should be reproducible from immutable event logs.
- Feature freshness must be monitored.

Feature freshness must be monitored.

A33. SOAR playbook design

Implementation detail

- Critical burst: block IP and force reset.
- Shared IP success: open case and inspect session activity.
- Low-and-slow probe: step-up MFA and watchlist.
- Broad IP velocity: enrich before containment.

Broad IP velocity: enrich before containment.

A34. Analyst feedback loop

Implementation detail

- Every alert needs close reason and true/false-positive label.
- Thresholds should be reviewed weekly during ramp.
- Precision by rule is more important than total alert count.
- Feedback creates the training data for future ML.

Feedback creates the training data for future ML.

A35. Interview Q&A: analytics choices

Backup talking points

- Q: Why not start with ML? A: no labels and explainability matters.
- Q: Why is baseline important? A: anomalies require a normal reference.
- Q: What would you do differently with more data? A: calibrate thresholds by user history.

Q: What would you do differently with more data? A: calibrate thresholds by user history.

A36. Interview Q&A: security judgment

Backup talking points

- Q: Is this proof of attack? A: no, it is high-confidence evidence.
- Q: What would you contain first? A: bursts and shared-IP simultaneous events.
- Q: What reduces false positives? A: enrichment, combinations of signals, analyst review.

Q: What reduces false positives? A: enrichment, combinations of signals, analyst review.

A37. Interview Q&A: product KPI case

Backup talking points

- Q: Is a signup spike good? A: only if quality metrics hold.
- Q: Which segments first? A: channel, geo, device, verification, activation.
- Q: How find a tracking bug? A: reconcile raw events, dedupe, and schema changes.

Q: How find a tracking bug? A: reconcile raw events, dedupe, and schema changes.

A38. Interview Q&A: production readiness

Backup talking points

- Q: What breaks in production? A: latency, schema drift, data gaps, alert fatigue.
- Q: How monitor the detector? A: precision, false positives, freshness, drift.
- Q: What is the first platform investment? A: enrichment and a governed feature store.

Q: What is the first platform investment? A: enrichment and a governed feature store.

A39. Interview Q&A: limitations

Backup talking points

- Q: Biggest limitation? A: no ground truth labels.
- Q: Weakest feature? A: off-hours alone, because context matters.
- Q: How defend thresholds? A: present them as triage heuristics, not final rules.

Q: How defend thresholds? A: present them as triage heuristics, not final rules.

A40. Source and asset provenance

Backup talking points

- Analytical charts: generated from the provided notebook/script and login workbook.
- Assignment brief: provided Word document in Downloads.
- Palo Alto Networks logo: Wikimedia Commons PNG preview of the 2020 SVG logo.
- Non-analytical hero/topology visuals: generated with image generation for this deck.

Non-analytical hero/topology visuals: generated with image generation for this deck.